

DGA Capital Management LP — Access Control Policy

Entity: DGA Capital Management LP (single-family office)

Scope: The DGA Capital portfolio/research application (web + mobile), its backend and database, the hosting and source-control accounts, and all data received from the Plaid API.

Owner: Alec Mazo, General Partner — alecmazo1@gmail.com

Last reviewed: 2026-06. Reviewed at least annually.

1. Principles

Access is governed by **least privilege**, **need-to-know**, and **deny-by-default**.

Users and systems receive only the minimum access required, and access to sensitive financial data is restricted to the General Partner.

2. Authentication

-
- Every user has a **unique account**; there are no shared or master ("god-mode") credentials.
 - Passwords are hashed with ****PBKDF2-HMAC-SHA256** (200,000 iterations, per-user random salt)**; plaintext passwords are never stored.
 - Session tokens are HMAC-signed with a secret that is **required** at startup — the application fails closed and will not issue or accept tokens if the secret is missing or set to a default value.

3. Authorization — role-based access control (RBAC)

-
- Roles: **GP/Admin** (full access) and **Limited Partner** (own fund data only).
 - All account/financial data, and all Plaid account connections, are restricted to the **GP/Admin** role.
 - Limited partners can view only their own fund's information; no cross-account access is possible.

4. Production and administrative access

-
- Access to the **hosting platform (Railway)** and **source control (GitHub)** is limited to the General Partner and protected by **multi-factor authentication**.
 - Application secrets (signing keys, encryption keys, third-party API keys) are

stored only in the platform's encrypted environment variables — never in source code, the client applications, or logs.

5. Non-human (service-to-service) authentication

Third-party data access uses **OAuth** (Plaid Link / institution OAuth) and server-held API keys; the institution's credentials are never received by this system. All service-to-service traffic is secured with **TLS 1.2+**.

6. Access provisioning and removal

- Access is granted by the GP on a need-to-know basis. The office has no employees or contractors, so there is no third-party on/off-boarding.
- Any linked institution can be disconnected on demand, which **revokes the access token at Plaid (/item/remove)** and purges the stored data^{**} for that connection.

7. Periodic access reviews

The General Partner reviews active user accounts and connected institutions/tokens **at least quarterly**, and removes any account, connection, or token that is no longer required.

8. Logging and monitoring

Authentication events and sensitive actions are recorded in an audit log. Credentials, tokens, and PII are redacted from logs; account numbers are stored only as the last-4 mask.

9. Policy review

This Access Control Policy is reviewed at least annually and after any material change to the application or its access model.